

DOCUMENTAÇÃO DE LABORATÓRIO

AWS IAM

Introdução ao Identity and Access Management

Serviço Principal
AWS IAM**Duração**
Aproximadamente 60 minutos**Nível**
Iniciante / Administração

1. Visão Geral

O AWS Identity and Access Management (IAM) é o serviço central de controle de acesso da AWS. Ele permite criar e gerenciar usuários, grupos e políticas que definem exatamente o que cada pessoa pode — e não pode — fazer dentro de uma conta AWS.

Neste laboratório, trabalhamos com um cenário empresarial real: uma empresa que está expandindo o uso da AWS e precisa conceder acesso a novos membros da equipe de acordo com suas funções. O desafio é aplicar o princípio do menor privilégio — cada usuário só deve ter acesso ao que realmente precisa.

1.1 Objetivos do Laboratório

- Criar e aplicar uma política de senhas personalizada para a conta AWS.
- Explorar usuários e grupos de usuários pré-criados no IAM.
- Inspecionar as políticas do IAM aplicadas a cada grupo.
- Adicionar usuários a grupos com permissões específicas.
- Localizar e usar o URL de login do IAM.
- Testar na prática os efeitos das políticas sobre o acesso aos serviços.

1.2 Cenário Empresarial

A empresa contratou três novos profissionais e cada um precisa de um nível diferente de acesso à AWS:

Usuário	Grupo	Permissões
user-1	S3-Support	Leitura no Amazon S3 (sem acesso ao EC2)
user-2	EC2-Support	Leitura no Amazon EC2 (sem poder alterar)
user-3	EC2-Admin	Visualizar, iniciar e parar instâncias EC2

2. Acesso ao Console de Gerenciamento da AWS

Antes de iniciar qualquer configuração, acessamos o Console Web da AWS pelo link do ambiente de laboratório.

1. Clicamos em **Start Lab** e aguardamos o círculo ficar verde (“status: ready”).
2. Abrimos o Console de Gerenciamento da AWS na nova aba — o login é feito automaticamente.
3. Anotamos a **região AWS ativa** exibida no canto superior direito (ex.: Oregon / us-west-2). Esse dado foi necessário mais tarde ao verificar instâncias EC2.

⚠ Atenção

A região AWS não foi alterada em nenhum momento durante o laboratório. Alterar a região pode fazer com que recursos (como instâncias EC2) desapareçam da visão.

3. Tarefa 1 — Criar uma Política de Senhas para a Conta

A primeira tarefa foi reforçar a segurança da conta configurando uma política de senhas mais rígida. Essa política se aplica a todos os usuários da conta.

3.1 Passos Realizados

4. No Console, pesquisamos por **IAM** e abrimos o serviço.
5. No painel lateral, clicamos em **Account settings** (Configurações da conta).
6. Clicamos em **Change password policy** para editar a política padrão.
7. Configuramos as seguintes opções e salvamos:

Configuração	Valor Definido
Comprimento mínimo da senha	10 caracteres
Exigir letras maiúsculas	Ativado
Exigir letras minúsculas	Ativado
Exigir números	Ativado
Exigir caracteres especiais	Ativado
Expiração da senha	90 dias
Evitar reuso de senhas	Últimas 5 senhas
Reset por administrador ao expirar	Não ativado

✅ Resultado

A política foi salva com sucesso. Todas as alterações têm efeito imediato e se aplicam a qualquer usuário que tentar criar ou redefinir uma senha na conta.

4. Tarefa 2 — Explorar Usuários e Grupos

Antes de atribuir usuários aos grupos, exploramos o que já havia sido pré-configurado no ambiente: os três usuários e os três grupos de usuários.

4.1 Usuários Pré-criados

Acessamos IAM > Usuários e inspecionamos cada perfil. O que encontramos:

- Nenhum dos três usuários (user-1, user-2, user-3) tinha permissões individuais atribuídas.
- Nenhum deles pertencia a qualquer grupo ainda.
- Todos possuíam senha de console configurada (credencial de acesso ao Console Web).

4.2 Grupos e suas Políticas

Acessamos cada grupo em IAM > Grupos de usuários e examinamos as políticas associadas:

1

Grupo EC2-Support

Política gerenciada pela AWS: **AmazonEC2ReadOnlyAccess**. Permite listar e descrever recursos do EC2, ELB, CloudWatch e Auto Scaling — sem permissão para alterar nada.

2

Grupo S3-Support

Política gerenciada pela AWS: **AmazonS3ReadOnlyAccess**. Permite listar e visualizar objetos dentro de buckets S3 — sem permissão para criar, editar ou excluir.

3

Grupo EC2-Admin

Política inline do cliente: **EC2-Admin-Policy**. Concede permissão para descrever, iniciar e interromper instâncias EC2. É uma política pontual, diferente das gerenciadas.

Política Gerenciada x Política Inline

Políticas gerenciadas são criadas de forma independente e podem ser reutilizadas em múltiplos grupos. Quando atualizadas, as mudanças se propagam automaticamente para todos os usuários/grupos que as utilizam. Políticas inline, por outro lado, estão embutidas diretamente em um único grupo ou usuário — são usadas para casos específicos e pontuais.

4.3 Estrutura de uma Política IAM (JSON)

Toda política IAM é um documento JSON com três campos fundamentais:

Campo	Significado
<code>Effect</code>	Define se a regra permite (Allow) ou nega (Deny) o acesso.
<code>Action</code>	Especifica qual chamada de API é afetada (ex.: <code>ec2:DescribeInstances</code> , <code>s3:GetObject</code>).
<code>Resource</code>	Define o escopo — um recurso específico (ex.: ARN de um bucket) ou * para

	qualquer recurso.
--	-------------------

5. Tarefa 3 — Adicionar Usuários aos Grupos

Com a estrutura entendida, adicionamos cada usuário ao grupo correto para que as permissões fossem herdadas automaticamente via política do grupo.

5.1 Procedimento Padrão (repetido para cada usuário)

8. Acessamos IAM > **Grupos de usuários**.
9. Selecionamos o grupo de destino.
10. Na guia **Usuários**, clicamos em **Adicionar usuários**.
11. Marcamos o usuário correspondente e confirmamos.

5.2 Atribuições Realizadas

Usuário	Adicionado ao grupo	Política herdada
user-1	S3-Support	AmazonS3ReadOnlyAccess
user-2	EC2-Support	AmazonEC2ReadOnlyAccess
user-3	EC2-Admin	EC2-Admin-Policy (inline)

Após as três atribuições, verificamos em IAM > Grupos de usuários que todos os grupos exibiam exatamente 1 usuário na coluna *Usuários*.

6. Tarefa 4 — Login e Teste das Permissões

A etapa mais prática do laboratório foi testar, com cada usuário, se as permissões configuradas funcionavam exatamente como esperado.

6.1 Preparar o Ambiente de Teste

12. Acessamos IAM > **Dashboard** e copiamos o URL de login de usuários IAM da conta.
13. Colamos o URL em um editor de texto para uso nas etapas seguintes.
14. Abrimos uma **janela privada/anônima** do navegador para evitar conflito de sessões.

URL de Login — Ocultado

O URL de login contém o ID numérico da conta AWS no formato `https://<ID-DA-CONTA>.signin.aws.amazon.com/console`. Esse dado é sensível e foi omitido neste documento.

6.2 Teste com user-1 (S3-Support)

15. Fizemos login com as credenciais do user-1 na janela privada.

16. Acessamos o serviço Amazon S3.
17. Conseguimos listar buckets e navegar pelo conteúdo — confirmação da permissão de leitura.
18. Acessamos o Amazon EC2 > Instâncias.
19. Recebemos a mensagem: **"You are not authorized to perform this operation"** — confirmando que o usuário não tem acesso ao EC2.
20. Encerramos a sessão do user-1.

6.3 Teste com user-2 (EC2-Support)

21. Fizemos login com as credenciais do user-2.
22. Acessamos EC2 > Instâncias. A instância foi listada normalmente.
23. Tentamos interromper a instância via **Instance state > Stop instance**.
24. Recebemos: **"Failed to stop the instance — You are not authorized to perform this operation"** — confirmando que a política é somente leitura.
25. Acessamos o Amazon S3 e recebemos: **"You don't have permissions to list buckets"**.
26. Encerramos a sessão do user-2.

6.4 Teste com user-3 (EC2-Admin)

27. Fizemos login com as credenciais do user-3.
28. Acessamos EC2 > Instâncias.
29. Tentamos interromper a instância via **Instance state > Stop instance**.
30. A instância entrou no estado **Stopping** e foi desligada com sucesso.
31. Encerramos a sessão e fechamos a janela privada.

Credenciais dos Usuários — Ocultadas

As senhas dos usuários de teste (user-1, user-2 e user-3) são credenciais do ambiente de laboratório e foram omitidas neste documento. Em ambientes reais, senhas nunca devem ser documentadas em texto simples.

7. Resumo dos Resultados de Teste

Usuário	Ação Testada	Resultado
user-1	S3-Support	✓ Listou buckets S3 com sucesso
user-1	S3-Support	✗ Acesso ao EC2 negado (sem permissão)
user-2	EC2-Support	✓ Listou instâncias EC2 com sucesso
user-2	EC2-Support	✗ Falha ao interromper instância (somente leitura)
user-2	EC2-Support	✗ Acesso ao S3 negado (sem permissão)
user-3	EC2-Admin	✓ Listou e interrompeu instância EC2

8. Lições Aprendidas

-  O princípio do menor privilégio é a base do IAM: cada identidade só deve ter acesso ao que realmente precisa para exercer sua função.
-  Grupos de usuários simplificam imensamente a administração. Atribuir permissões a grupos (e não a indivíduos) torna o gerenciamento escalável e auditável.
-  Políticas gerenciadas pela AWS (como AmazonEC2ReadOnlyAccess) são atualizadas pela própria Amazon e propagadas automaticamente. Políticas inline dão mais controle pontual, mas exigem manutenção manual.
-  Políticas de senha são a primeira linha de defesa. Exigir comprimento mínimo, complexidade e renovação periódica reduz significativamente o risco de comprometimento de contas.
-  O URL de login IAM e as credenciais de usuários são informações sensíveis. Não devem ser compartilhadas, documentadas em texto simples ou expostas em repositórios públicos.
-  Testar as permissões com os próprios usuários (login real, não apenas inspeção de políticas) é a forma mais confiável de validar que a configuração está funcionando como esperado.

9. Conclusão

Este laboratório proporcionou uma experiência prática e completa do ciclo de gerenciamento de identidades e acesso na AWS. Partimos de um ambiente sem nenhuma atribuição de permissões, estruturamos grupos com políticas adequadas, adicionamos usuários e validamos tudo na prática.

O que ficou claro ao final: a configuração correta do IAM não é apenas uma boa prática de segurança — é a base que sustenta qualquer ambiente AWS confiável. Cada clique de "acesso negado" que vimos durante os testes foi, na verdade, o sistema funcionando exatamente como deveria.

Documentação elaborada após a conclusão do laboratório. Dados sensíveis (URL de login IAM, IDs de conta, credenciais de usuários) foram propositalmente ocultados.